

6.4 Logging and Monitoring

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Record security events, detect and respond to anomalous actions and operations within the user's Swift environment. In-scope components: • Data exchange layer: network • Operating system of a dedicated and general-purpose operator PC • jump server • Swift-related components (including interfaces, GUI, Swift and customer (client) connectors) • customer client connector • systems or virtual machines hosting Swift-related components • network devices protecting the secure zone and HSM or the customer client connectors • database linked to a messaging interface or a customer connector • authentication or authorisation servers, or both, controlling accesses to the secure zone • on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform hosting Swift-related VMs, including the Alliance Connect Virtual on Premises VPN • bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components Risk Drivers: • lack of traceability • undetected anomalies or suspicious activity						
<u>Implementation Guidance</u> Control Statement: Capabilities to detect anomalous activity are implemented, and a process or tool is in place to keep and review logs. Control Context: Developing a logging and monitoring plan is the basis for effectively detecting abnormal behaviour and potential attacks and support further investigations. As the operational environment becomes more complex, so will the logging and monitoring capability needed to perform adequate detection. Simplifying the operational environment will enable simpler logging and monitoring. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). • Overall goals for logging and monitoring: – Implement a plan to log security-relevant activities and configure alarms for suspicious security events (when supported by the application). – Implement a plan to monitor security events in logs and to monitor other data (for example, real-time business activities through the GUI), and establish a plan to treat reported alarms.						

- Support investigations and forensics in case of potential breach through log retention, in line with applicable laws and regulations.
- Logging:
 - Logging capabilities are implemented to detect and support analysis of abnormal usage within the secure zone and any attempts to undermine the effectiveness of controls within the secure zone.
 - Logs provide traceability of account usage to the appropriate individual.
 - Minimum logs to be recorded include:
 - Command-line history for privileged operating system accounts on servers
 - Messaging and communication interface application and operating system logs which detail abnormal system behaviour (for example, activity outside normal business hours, multiple failed login attempts, authentication errors, changes to user groups)
 - Firewall logs
 - Database logs (if available, and as a minimum in the case of hosted database solutions).
- Monitoring:
 - Procedures are in place to identify suspicious login activities into any privileged operating system or application accounts within the secure zone.
 - Monitoring processes are in place to review server, application, and database monitoring data of the secure zone either daily through human review or through automated monitoring with alerting.
 - Monitoring processes are in place to review network-monitoring data on a regular basis.
 - Unusual or suspicious activity is reported for further investigation to the appropriate security team.
- Log retention:
 - All logging and monitoring activities comply with applicable laws, regulations, and employment contracts which supersede other implementation guidance.
 - Messaging and communication interface application audit logs are retained for no less than 12 months and are sufficiently protected from an enterprise administrator-level compromise (for example, log files are transferred to a separate system with different system administrator credentials).
 - Operator PC, firewall, and database audit logs are retained for no less than 31 days (it is recommended to extend firewall and database audit logs retention to three months and possibly 12 months to support longer investigations).
 - Audit logs captured on other identified in-scope components, at application level or system level, are retained for no less than 12 months.
 - Prevent audit log loss by considering a range of configurable choices when log storage is to be exhausted. As examples, such choices can include log rotation, degraded mode or ignoring some events.

Optional Enhancements:

- A centralised logging capability is implemented, minimising the number of log locations to be inspected.
- Session recording is implemented to record all activity conducted by privileged accounts on Swift secure zone servers.
- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.